Cetus-CLMM

Audit Report





contact@bitslab.xyz



https://twitter.com/movebit_

Mon Sep 14 2026

Cetus-CLMM Audit Report

1 Executive Summary

1.1 Project Information

Description	Cetus-CLMM is an AMM on Sui.
Type	Dex
Auditors	N0n3, poetyellow
Timeline	Fri Sep 11 2026 - Mon Sep 14 2026
Languages	Move
Platform	Sui
Methods	Architecture Review, Unit Testing, Manual Review
Source Code	https://github.com/CetusProtocol/cetus-contracts
Commits	f7f62b49b74cf4da948c325f210638d73cdefac7

1.2 Files in Scope

The following are the SHA1 hashes of the original reviewed files.

ID	File	SHA-1 Hash
CON	packages/cetus_clmm/sources/config.move	a9155bb77c8b39b3c8bcf27e89b2b439c9198e81

1.3 Issue Statistic

Item	Count	Fixed	Acknowledged
Total	0	0	0
Critical	0	0	0
Major	0	0	0
Medium	0	0	0
Minor	0	0	0
Informational	0	0	0

1.4 MoveBit Audit Breakdown

ScaleBit aims to assess repositories for security-related issues, code quality, and compliance with specifications and best practices. Possible issues our team looked for included (but are not limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Integer overflow/underflow
- Number of rounding errors
- Unchecked External Call
- Unchecked CALL Return Values
- Functionality Checks
- Reentrancy
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic issues
- Gas usage
- Fallback function usage
- tx.origin authentication
- Replay attacks
- Coding style issues

1.5 Methodology

The security team adopted the **"Testing and Automated Analysis"**, **"Code Review"** and **"Formal Verification"** strategy to perform a complete security test on the code in a way that is closest to the real attack. The main entrance and scope of security testing are stated in the conventions in the "Audit Objective", which can expand to contexts beyond the scope according to the actual testing needs. The main types of this security audit include:

(1) Testing and Automated Analysis

Items to check: state consistency / failure rollback / unit testing / value overflows / parameter verification / unhandled errors / boundary checking / coding specifications.

(2) Code Review

The code scope is illustrated in section 1.2.

(3) Audit Process

- Carry out relevant security tests on the testnet or the mainnet;
- If there are any questions during the audit process, communicate with the code owner in time. The code owners should actively cooperate (this might include providing the latest stable source code, relevant deployment scripts or methods, transaction signature scripts, exchange docking schemes, etc.);
- The necessary information during the audit process will be well documented for both the audit team and the code owner in a timely manner.

2 Summary

This report has been commissioned by Cetus-CLMM to identify any potential issues and vulnerabilities in the source code of the Cetus-CLMM smart contract. In this audit, we have utilized various techniques, including manual code review and static analysis, to identify potential vulnerabilities and security issues.
This audit scope only include this PR : "https://github.com/CetusProtocol/cetus-clmm-sui/pull/61"

During the audit, we identified 0 issues of varying severity, listed below.

ID	Title	Severity	Status

3 Participant Process

Here are the relevant actors with their respective abilities within the Cetus-CLMM Smart Contract :

Admin

- The `AdminCap` holder can manage roles, update the package version, issue protocol fee collection capabilities, and withdraw tokens from the reward vault.

Managers

- Pool managers can manage coin allowlists and denylists, mint `PoolCreationCap`, create pools, and update pool fees and operational status.
- Fee tier managers can add, remove, and update fee tiers.
- Rewarder managers can initialize pool rewards and update emission rates.
- Partner managers can create partners and update their referral fee rates and active periods.
- Protocol fee collectors can claim accumulated protocol fees.
- Emergency role holders can pause or resume the protocol according to their assigned permissions.

Partner

- `PartnerCap` holders can claim referral fees from their associated partners.

User

- Users can call `mint_pool_creation_cap` with their `TreasuryCap` to obtain a `PoolCreationCap`.
- `PoolCreationCap` holders can register and unregister permissioned pairs and create their associated pools.
- Users can create eligible non-permissioned pools, manage liquidity positions, and collect position fees and rewards.
- Users can perform flash swaps and flash loans with repayment in the same transaction.

4 Findings

Appendix 1

Issue Level

- **Informational** issues are often recommendations to improve the style of the code or to optimize code that does not affect the overall functionality.
- **Minor** issues are general suggestions relevant to best practices and readability. They don't pose any direct risk. Developers are encouraged to fix them.
- **Medium** issues are non-exploitable problems and not security vulnerabilities. They should be fixed unless there is a specific reason not to.
- **Major** issues are security vulnerabilities. They put a portion of users' sensitive information at risk, and often are not directly exploitable. All major issues should be fixed.
- **Critical** issues are directly exploitable security vulnerabilities. They put users' sensitive information at risk. All critical issues should be fixed.

Issue Status

- **Fixed:** The issue has been resolved.
- **Partially Fixed:** The issue has been partially resolved.
- **Acknowledged:** The issue has been acknowledged by the code owner, and the code owner confirms it's as designed, and decides to keep it.

Appendix 2

Disclaimer

This report is based on the scope of materials and documents provided, with a limited review at the time provided. Results may not be complete and do not include all vulnerabilities. The review and this report are provided on an as-is, where-is, and as-available basis. You agree that your access and/or use, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your own risk. A report does not imply an endorsement of any particular project or team, nor does it guarantee its security. These reports should not be relied upon in any way by any third party, including for the purpose of making any decision to buy or sell products, services, or any other assets. TO THE FULLEST EXTENT PERMITTED BY LAW, WE DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, IN CONNECTION WITH THIS REPORT, ITS CONTENT, RELATED SERVICES AND PRODUCTS, AND YOUR USE, INCLUDING BUT NOT LIMITED TO THE IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, NOT INFRINGEMENT.

